

VujaDe Platform - Developer Bug Report & Remediation Guide

Introduction

This document outlines the critical and high-priority bugs identified during the Quality Assurance (QA) Round 2 testing of the VujaDe Platform. It provides detailed descriptions of the failures, their locations within the application, and actionable recommendations for remediation.

1. Critical Security Vulnerabilities

1.1 Insecure Direct Object Reference (IDOR) & Authorization Bypass

- **Issue:** Employees can access restricted pages (e.g., 'Pricing Admin') and client dashboards directly via URL manipulation.
- **Failed Scenarios:** E_R2_001 , E_R2_005
- **Location:** Routing and middleware logic for `/internal/pricing-admin` and client profile endpoints.
- **Recommendation:** Implement robust role-based access control (RBAC) checks at the controller/middleware level for *every* endpoint. Do not rely solely on hiding UI elements. Ensure that the authenticated user's role explicitly grants access to the requested resource before rendering the view or returning data.

1.2 Unauthorized Modification of Project Budget

- **Issue:** Project Managers can unilaterally change the project budget after the client has approved the final quote, without triggering any re-approval workflow or warnings.
- **Failed Scenario:** PM_R2_007
- **Location:** Project Edit functionality (`/internal/projects/show/{id}`).
- **Recommendation:** Implement state-dependent validation. If a project's status indicates that the quote has been approved, lock the budget field in the UI for Project Managers. Any required changes should trigger a formal "Change Request" workflow that requires client re-approval.

1.3 Unauthorized Modification of Client Projects

- **Issue:** Project Managers can modify client project details (like the title) without proper access control checks ensuring they are assigned to that specific project or have global edit rights.
- **Failed Scenario:** M_R2_007
- **Location:** Project Edit functionality.
- **Recommendation:** Enforce strict ownership/assignment checks. A Project Manager should only be able to edit projects to which they are explicitly assigned, unless they hold a higher administrative role.

1.4 Client Role Permission Modification Failure

- **Issue:** Attempting to save modifications to Client role permissions results in a 404 Not Found error.
- **Failed Scenario:** M_R2_013
- **Location:** Role/Permission management endpoints (likely under `/internal/permissions`).
- **Recommendation:** Investigate the routing for the permission update submission. Ensure the endpoint exists, accepts the correct HTTP method (e.g., POST/PUT), and correctly processes the payload.

2. High-Priority Functional Defects

2.1 Document Upload Failure

- **Issue:** Employees attempting to upload deliverables experience a silent failure; the modal remains open, and no success or error message is displayed.
- **Failed Scenario:** E_R2_004
- **Location:** Document upload modal on the Project Details page (`/internal/projects/show/{id}`).
- **Recommendation:** Debug the frontend form submission logic and the backend file handling endpoint. Ensure proper error handling is in place to catch upload failures (e.g., file size limits, unsupported types, server errors) and display user-friendly error messages in the UI.

2.2 Negative Quantity in Pricing Tool

- **Issue:** The system allows users to input negative quantities for pricing items, leading to incorrect total calculations.
- **Failed Scenario:** E_R2_007

- **Location:** Pricing Tool interface (`/internal/pricing-tool`).
- **Recommendation:** Add frontend HTML5 validation (`min="0"`) to the quantity input fields. Crucially, implement backend validation to reject any payload containing negative quantities for pricing items.

2.3 Quote Approval UI Unresponsive

- **Issue:** When a Manager attempts to approve a quote that was modified by an Employee, the 'Approve Quote' button does not change status, and there is no visual feedback indicating success or failure.
- **Failed Scenario:** `M_R2_001`
- **Location:** Quote approval interface within Project Requests (`/internal/projects/show/{id}`).
- **Recommendation:** Investigate the AJAX/fetch call triggered by the 'Approve Quote' button. Ensure the backend correctly processes the approval state change and returns a success response. Update the frontend logic to handle this response, update the UI state (e.g., disable the button, change text to 'Approved'), and display a toast notification.

2.4 Missing Project Closure/Archive Functionality

- **Issue:** Project Managers cannot close or archive projects, especially those with pending scope change requests, because the explicit option is missing from the UI.
- **Failed Scenario:** `PM_R2_002`
- **Location:** Project Details / Edit Project modal.
- **Recommendation:** Implement a clear 'Close Project' or 'Archive Project' action. Add validation logic to check for pending requests or open tasks before allowing closure, and display appropriate warnings or blockers to the user.

2.5 Logical Inconsistency: Milestones on Completed Projects

- **Issue:** The system allows Project Managers to add new milestones to projects that are already marked as 'Completed'.
- **Failed Scenario:** `PM_R2_004`
- **Location:** Milestone creation interface on Project Details page.
- **Recommendation:** Disable the 'Add Milestone' button and associated API endpoints for any project that has a 'Completed' status.

2.6 Missing Financial Reports

- **Issue:** Managers attempting to view general financial reports encounter a 404 Not Found page.
- **Failed Scenario:** M_R2_008
- **Location:** Financial reporting navigation link/endpoint.
- **Recommendation:** Verify if the financial reporting module is implemented. If it is, fix the broken routing. If it is a planned feature not yet built, remove or disable the link in the UI to prevent user confusion.

2.7 Duplicate Service Creation UX

- **Issue:** While the system prevents creating a service with a duplicate name (returning a 403 Forbidden), the user experience is poor, likely resulting in a generic error page rather than a helpful validation message.
- **Failed Scenario:** M_R2_010
- **Location:** Pricing Admin / Service Creation form.
- **Recommendation:** Catch the duplicate entry exception on the backend and return a standard validation error response (e.g., 422 Unprocessable Entity). Update the frontend to display this specific error message next to the service name input field.

2.8 Pricing Rule Deletion Automation Blocker

- **Issue:** Deleting a pricing rule relies on a native JavaScript confirmation dialog (`confirm()`), which can be problematic for automated testing and provides a subpar user experience.
- **Failed Scenario:** M_R2_011
- **Location:** Pricing Admin page.
- **Recommendation:** Replace the native `confirm()` dialog with a custom, styled modal component (e.g., using Bootstrap or Tailwind modals) for destructive actions. This improves UX and makes automated testing more reliable.

Conclusion

Addressing these issues, particularly the critical security vulnerabilities (IDOR and unauthorized modifications), should be the immediate priority for the development team. Implementing robust backend validation and improving frontend error handling will significantly enhance the platform's stability and user experience.